

## 2.3 — POLITIQUE FIREWALL OPNSENSE

✍ Rédacteur : Équipe Infrastructure CYNA • Équipement : OPNsense (VM 200) • Date : Mars 2026

**Principe général — Zero Trust** : par défaut, aucun VLAN ne communique avec un autre. Chaque flux doit être explicitement autorisé par une règle. Les règles sont lues de haut en bas (première correspondance = action appliquée). Toute tentative non couverte est bloquée par la règle implicite `BLOCK ALL` en fin de liste.

### 1. Plan d'adressage et zones de sécurité

| VLAN | Nom               | Réseau       | Niveau sécurité | Composants hébergés                                                                                        |
|------|-------------------|--------------|-----------------|------------------------------------------------------------------------------------------------------------|
| 10   | Endpoints / Users | 10.0.10.0/24 | Moyen           | VM 112 (PFR-CYPO002 Win11) — Postes utilisateurs joints au domaine cyna.labo                               |
| 20   | DMZ               | 10.0.20.0/24 | Moyen+          | LXC 105 (Nginx Reverse Proxy 10.0.20.2) — Point d'entrée HTTPS, terminaison TLS, auth_request Authelia     |
| 30   | Invités WiFi      | 10.0.30.0/24 | Faible          | Appareils invités — Accès Internet uniquement, isolation totale du SI interne                              |
| 40   | Serveurs internes | 10.0.40.0/24 | Élevé           | VM 199 (AD 10.0.40.2) • VM 205 (Wazuh 10.0.40.3) • LXC 104 (Authelia 10.0.40.5) • LXC 150 (VPN 10.0.40.10) |
| 50   | Stockage          | 10.0.50.0/28 | Élevé           | VM 207 (TrueNAS 10.0.50.2) — Partages SMB/NFS, profils itinérants, données utilisateurs                    |
| 60   | Administration    | 10.0.60.0/28 | Critique        | VM 201 (Bastion SSH 10.0.60.2) • LXC 108 (Ansible 10.0.60.5) — Accès admin exclusif via bastion            |

### 2. Objets et alias OPNsense

| Nom de l'alias | Valeur(s)    | Description                                               |
|----------------|--------------|-----------------------------------------------------------|
| NET_USERS      | 10.0.10.0/24 | VLAN 10 — Endpoints utilisateurs                          |
| NET_DMZ        | 10.0.20.0/24 | VLAN 20 — Zone démilitarisée (Nginx)                      |
| NET_GUESTS     | 10.0.30.0/24 | VLAN 30 — Invités WiFi (isolation totale)                 |
| NET_SERVERS    | 10.0.40.0/24 | VLAN 40 — Serveurs internes (AD, Wazuh, Authelia, VPN)    |
| SRV_AD         | 10.0.40.2    | Active Directory / DNS interne (VM 199 — Win Server 2022) |
| SRV_WAZUH      | 10.0.40.3    | SIEM Wazuh Manager + OpenSearch (VM 205)                  |
| SRV_AUTHELIA   | 10.0.40.5    | Portail MFA Authelia — LXC 104                            |

| Nom de l'alias | Valeur(s)                                    | Description                                                                               |
|----------------|----------------------------------------------|-------------------------------------------------------------------------------------------|
| SRV_VPN_LXC    | 10.0.40.10                                   | WireGuard VPN instance LXC — LXC 150                                                      |
| NET_STORAGE    | 10.0.50.0/28                                 | VLAN 50 — Stockage NAS                                                                    |
| SRV_TRUENAS    | 10.0.50.2                                    | TrueNAS — Partages SMB/NFS, backup FreeFileSync (VM 207)                                  |
| NET_ADMIN      | 10.0.60.0/28                                 | VLAN 60 — Administration (Bastion + Ansible)                                              |
| SRV_BASTION    | 10.0.60.2                                    | Bastion SSH — seul point d'accès admin aux VMs critiques (VM 201)                         |
| SRV_ANSIBLE    | 10.0.60.5                                    | Nœud de contrôle Ansible — déploiements automatisés (LXC 108)                             |
| SRV_NGINX      | 10.0.20.2                                    | Reverse proxy Nginx — terminaison TLS (LXC 105)                                           |
| PORTS_AD       | 53, 88, 135, 389, 445, 636, 3268             | Ports Active Directory : DNS, Kerberos, RPC, LDAP, SMB, LDAPS, Global Catalog             |
| PORTS_WAZUH    | 1514, 1515, 55000                            | Ports Wazuh : agent communication (1514 UDP/TCP), enrollment (1515), API REST (55000)     |
| !RFC1918       | !10.0.0.0/8, !172.16.0.0/12, !192.168.0.0/16 | Négation des réseaux privés — utilisé pour autoriser Internet tout en bloquant inter-VLAN |

### 3. Matrice globale des flux inter-VLAN

Lecture : ✓ **PASS** = flux autorisé • ✗ **BLOCK** = flux bloqué • — = non applicable (même VLAN ou flux inutile)

| Source \ Destination | VLAN 10 Endpoints | VLAN 20 DMZ | VLAN 30 Invités | VLAN 40 Serveurs         | VLAN 50 Stockage | VLAN 60 Admin      | Internet    |
|----------------------|-------------------|-------------|-----------------|--------------------------|------------------|--------------------|-------------|
| VLAN 10 — Endpoints  | —                 | ✓ TCP 443   | ✗               | ✓ PORTS_AD               | ✓ SMB 445        | ✗                  | ✓           |
| VLAN 20 — DMZ        | ✗                 | —           | ✗               | ✓ TCP 9200<br>OpenSearch | ✗                | ✗                  | ✓           |
| VLAN 30 — Invités    | ✗                 | ✗           | —               | ✗                        | ✗                | ✗                  | ✓ HTTP/S    |
| VLAN 40 — Serveurs   | ✗                 | ✗           | ✗               | —                        | ✓ SMB/NFS        | ✓ SSH 22 (Ansible) | ✓ limité    |
| VLAN 50 — Stockage   | ✗                 | ✗           | ✗               | ✗                        | —                | ✓ SSH 22 (admin)   | ✓ S3 backup |
| VLAN 60 — Admin      | ✓ SSH 22          | ✓ SSH 22    | ✗               | ✓ SSH 22                 | ✓ SSH 22 TCP 443 | —                  | ✓ limité    |

### 4. Règles détaillées par interface VLAN

Les règles ci-dessous sont appliquées en entrée (*Inbound*) sur chaque interface VLAN. Première correspondance = action appliquée. Règle implicite finale : *BLOCK ALL*.

#### VLAN 10 — Endpoints utilisateurs (10.0.10.0/24)

| Priorité | Action | Proto   | Source    | Destination | Port(s)    | Description                                                                    |
|----------|--------|---------|-----------|-------------|------------|--------------------------------------------------------------------------------|
| 01       | PASS   | TCP/UDP | NET_USERS | SRV_AD      | PORTS_AD   | Authentification Kerberos, DNS interne, LDAP, partages SMB Active Directory    |
| 02       | PASS   | TCP     | NET_USERS | SRV_NGINX   | 443        | Accès aux applications internes via reverse proxy Nginx (DMZ)                  |
| 03       | PASS   | TCP/UDP | NET_USERS | SRV_WAZUH   | 1514, 1515 | Remontée des logs agents Wazuh (enrollment + communication)                    |
| 04       | PASS   | TCP     | NET_USERS | SRV_TRUENAS | 445        | Accès partages réseau SMB (montage lecteurs via GPO)                           |
| 05       | BLOCK  | TCP     | NET_USERS | SRV_TRUENAS | 80, 443    | Interdiction accès interface Web d'administration TrueNAS                      |
| 06       | BLOCK  | ANY     | NET_USERS | NET_ADMIN   | ANY        | Isolation totale du VLAN Administration — aucun accès direct depuis endpoints  |
| 07       | BLOCK  | ANY     | NET_USERS | NET_STORAGE | ANY        | Isolation VLAN Stockage — seul SMB via règle 04 est autorisé                   |
| 08       | PASS   | ANY     | NET_USERS | !RFC1918    | ANY        | Accès Internet (kill-switch inter-VLAN : bloque tout réseau privé non couvert) |
| 99       | BLOCK  | ANY     | NET_USERS | ANY         | ANY        | Règle implicite — tout trafic non couvert est bloqué                           |

## VLAN 20 — DMZ / Reverse Proxy Nginx (10.0.20.0/24)

| Priorité | Action | Proto | Source  | Destination  | Port(s) | Description                                                     |
|----------|--------|-------|---------|--------------|---------|-----------------------------------------------------------------|
| 01       | PASS   | TCP   | NET_DMZ | SRV_AUTHELIA | 9091    | Nginx → Authelia : vérification MFA via auth_request            |
| 02       | PASS   | TCP   | NET_DMZ | SRV_WAZUH    | 9200    | Nginx → OpenSearch Dashboard (consultation logs SIEM)           |
| 03       | PASS   | TCP   | NET_DMZ | SRV_AD       | 53, 389 | Résolution DNS interne et requêtes LDAP pour Authelia           |
| 04       | BLOCK  | ANY   | NET_DMZ | NET_USERS    | ANY     | Interdiction accès retour DMZ → Endpoints (isolation)           |
| 05       | BLOCK  | ANY   | NET_DMZ | NET_STORAGE  | ANY     | Interdiction accès DMZ → Stockage (NAS non exposé)              |
| 06       | BLOCK  | ANY   | NET_DMZ | NET_ADMIN    | ANY     | Interdiction accès DMZ → Administration                         |
| 07       | PASS   | ANY   | NET_DMZ | !RFC1918     | ANY     | Accès Internet (mises à jour paquets Nginx, Let's Encrypt ACME) |
| 99       | BLOCK  | ANY   | NET_DMZ | ANY          | ANY     | Règle implicite — tout trafic non couvert est bloqué            |

## VLAN 30 — Invités WiFi (10.0.30.0/24)

| Priorité | Action       | Proto | Source     | Destination        | Port(s) | Description                                            |
|----------|--------------|-------|------------|--------------------|---------|--------------------------------------------------------|
| 01       | <b>BLOCK</b> | ANY   | NET_GUESTS | !RFC1918 (inversé) | ANY     | Isolation totale du SI — aucun accès aux VLAN internes |
| 02       | <b>PASS</b>  | TCP   | NET_GUESTS | ANY                | 80, 443 | Navigation HTTP/HTTPS Internet uniquement              |
| 03       | <b>PASS</b>  | UDP   | NET_GUESTS | ANY                | 53      | Résolution DNS (serveur DNS public — ex: 1.1.1.1)      |
| 99       | <b>BLOCK</b> | ANY   | NET_GUESTS | ANY                | ANY     | Règle implicite — tout autre trafic bloqué             |

### VLAN 40 — Serveurs internes (10.0.40.0/24)

| Priorité | Action       | Proto | Source       | Destination | Port(s)   | Description                                                                     |
|----------|--------------|-------|--------------|-------------|-----------|---------------------------------------------------------------------------------|
| 01       | <b>PASS</b>  | UDP   | SRV_WAZUH    | NET_USERS   | 514       | Wazuh → syslog agents (collecte logs endpoints VLAN 10)                         |
| 02       | <b>PASS</b>  | TCP   | SRV_AD       | SRV_TRUENAS | 445       | AD → TrueNAS SMB (profils itinérants, authentification domaine)                 |
| 03       | <b>PASS</b>  | TCP   | SRV_AUTHELIA | SRV_AD      | 389, 636  | Authelia → LDAP/LDAPS Active Directory (authentification compte de service)     |
| 04       | <b>PASS</b>  | TCP   | NET_SERVERS  | SRV_TRUENAS | 445, 2049 | Accès SMB/NFS vers stockage NAS depuis les serveurs internes                    |
| 05       | <b>PASS</b>  | TCP   | NET_SERVERS  | NET_ADMIN   | 22        | Serveurs → Bastion/Ansible SSH (administration)                                 |
| 06       | <b>PASS</b>  | ANY   | NET_SERVERS  | !RFC1918    | ANY       | Accès Internet limité (mises à jour OS, dépôts Debian/Ubuntu, WindowsUpdate AD) |
| 07       | <b>BLOCK</b> | ANY   | NET_SERVERS  | NET_USERS   | ANY       | Interdiction accès retour Serveurs → Endpoints (sans règle explicite)           |
| 99       | <b>BLOCK</b> | ANY   | NET_SERVERS  | ANY         | ANY       | Règle implicite — tout trafic non couvert est bloqué                            |

### VLAN 50 — Stockage / TrueNAS (10.0.50.0/28)

| Priorité | Action       | Proto | Source      | Destination | Port(s)   | Description                                                 |
|----------|--------------|-------|-------------|-------------|-----------|-------------------------------------------------------------|
| 01       | <b>PASS</b>  | TCP   | NET_USERS   | SRV_TRUENAS | 445       | Endpoints → TrueNAS SMB (montage lecteurs réseau via GPO)   |
| 02       | <b>PASS</b>  | TCP   | NET_SERVERS | SRV_TRUENAS | 445, 2049 | Serveurs → TrueNAS SMB/NFS (profils itinérants AD, données) |
| 03       | <b>BLOCK</b> | TCP   | NET_USERS   | SRV_TRUENAS | 80, 443   | Interdiction accès interface Web administration TrueNAS     |

| Priorité | Action | Proto | Source      | Destination | Port(s) | Description                                                                     |
|----------|--------|-------|-------------|-------------|---------|---------------------------------------------------------------------------------|
| 04       | BLOCK  | TCP   | NET_SERVERS | SRV_TRUENAS | 80, 443 | Interdiction accès interface Web TrueNAS depuis serveurs                        |
| 05       | PASS   | TCP   | SRV_TRUENAS | !RFC1918    | ANY     | TrueNAS → Cloud S3 : synchronisation backup FreeFileSync (cron 02h00 quotidien) |
| 06       | PASS   | TCP   | NET_ADMIN   | SRV_TRUENAS | 22, 443 | Admin (Bastion/Ansible) → TrueNAS SSH + interface Web d'administration          |
| 07       | BLOCK  | ANY   | SRV_TRUENAS | NET_USERS   | ANY     | TrueNAS ne peut pas initier de connexion vers les endpoints                     |
| 99       | BLOCK  | ANY   | NET_STORAGE | ANY         | ANY     | Règle implicite — tout trafic non couvert est bloqué                            |

### VLAN 60 — Administration / Bastion (10.0.60.0/28)

| Priorité | Action | Proto | Source      | Destination | Port(s)    | Description                                                                     |
|----------|--------|-------|-------------|-------------|------------|---------------------------------------------------------------------------------|
| 01       | PASS   | TCP   | SRV_BASTION | NET_SERVERS | 22         | Bastion SSH → tous les serveurs VLAN 40 (administration)                        |
| 02       | PASS   | TCP   | SRV_BASTION | SRV_TRUENAS | 22, 443    | Bastion → TrueNAS SSH + Web admin (gestion NAS)                                 |
| 03       | PASS   | TCP   | SRV_BASTION | NET_USERS   | 3389       | Bastion → Endpoints RDP (dépannage postes utilisateurs si nécessaire)           |
| 04       | PASS   | TCP   | SRV_ANSIBLE | NET_SERVERS | 22         | Ansible → Serveurs SSH (playbooks de déploiement et durcissement)               |
| 05       | PASS   | TCP   | SRV_ANSIBLE | NET_USERS   | 5985, 5986 | Ansible → Endpoints WinRM (déploiement agents, GPO complémentaires)             |
| 06       | PASS   | TCP   | SRV_ANSIBLE | SRV_TRUENAS | 22         | Ansible → TrueNAS SSH (automatisation configuration NAS)                        |
| 07       | BLOCK  | ANY   | NET_ADMIN   | NET_GUESTS  | ANY        | Interdiction accès VLAN Invités depuis Administration                           |
| 08       | PASS   | ANY   | NET_ADMIN   | !RFC1918    | ANY        | Admin → Internet limité (téléchargement playbooks Ansible Galaxy, mises à jour) |
| 99       | BLOCK  | ANY   | NET_ADMIN   | ANY         | ANY        | Règle implicite — tout trafic non couvert est bloqué                            |

### Interface WAN — Règles entrantes (Internet → OPNsense)

| Priorité | Action | Proto | Source | Destination | Port(s) | Description                                              |
|----------|--------|-------|--------|-------------|---------|----------------------------------------------------------|
| 01       | PASS   | UDP   | ANY    | IP_WAN      | 51820   | WireGuard VPN — seul port exposé sur Internet (UDP)      |
| 02       | BLOCK  | ANY   | ANY    | ANY         | ANY     | Bloquer tout trafic entrant non sollicité (stealth mode) |

## 5. Analyse de sécurité et justifications

- **Principe du moindre privilège** : chaque VLAN n'accède qu'aux ressources strictement nécessaires à son fonctionnement. Les endpoints (VLAN 10) peuvent consommer AD, SMB et Nginx, mais ne peuvent pas administrer les serveurs (SSH bloqué) ni l'interface TrueNAS.
- **Kill-switch inter-VLAN (règle !RFC1918)** : la règle d'accès Internet utilise la négation des plages privées comme filet de sécurité. Tout VLAN non couvert par une règle explicite ne peut pas router vers les autres VLAN internes.
- **Isolation du VLAN Invités (VLAN 30)** : accès Internet uniquement (TCP 80/443 + DNS). Aucune route vers le SI interne. Idéal pour les appareils BYOD ou visiteurs.
- **VLAN Administration (VLAN 60) inaccessible depuis les endpoints** : le bastion (10.0.60.2) est le seul point d'entrée SSH vers toutes les VMs. Aucune connexion directe machine→serveur n'est possible sans passer par ce bastion.
- **Interface Web TrueNAS bloquée depuis le réseau utilisateur** : la gestion du NAS est réservée au VLAN 60 (Bastion/Ansible). Les utilisateurs peuvent monter des partages SMB mais ne peuvent pas modifier la configuration du NAS.
- **Syslog OPNsense → Wazuh (UDP 514)** : tous les événements firewall (règles bloquées, connexions VPN) sont envoyés vers Wazuh Manager pour corrélation et alerting dans OpenSearch Dashboard.
- **Un seul port Internet exposé** : seul UDP/51820 (WireGuard) est ouvert en entrée WAN. Toutes les autres tentatives de connexion entrante sont bloquées en mode stealth (pas de réponse ICMP).

## 6. Procédures de test et validation

Tests à effectuer depuis chaque zone pour valider la politique firewall :

### Depuis un endpoint VLAN 10 (10.0.10.x)

- **✓ Succès attendu** : `ping cyna.labo` → résolution DNS via AD (10.0.40.2)
- **✓ Succès attendu** : `net use \\10.0.50.2\partage` → montage lecteur SMB TrueNAS
- **✓ Succès attendu** : Accès `https://app.cyna.labo` via Nginx + Authelia MFA
- **X Échec attendu** : `https://10.0.50.2` → Interface Web TrueNAS bloquée (règle 05)
- **X Échec attendu** : `ssh 10.0.40.3` → SSH Wazuh bloqué (accès admin réservé au bastion)
- **X Échec attendu** : `ping 10.0.60.2` → VLAN Admin inaccessible depuis endpoints

### Depuis le bastion VLAN 60 (10.0.60.2)

- **✓ Succès attendu** : `ssh 10.0.40.3` → SSH Wazuh Manager
- **✓ Succès attendu** : `ssh 10.0.50.2` → SSH TrueNAS
- **✓ Succès attendu** : `ssh 10.0.40.2` → SSH Active Directory (si SSH activé)

### Depuis le VLAN Invités (10.0.30.x)

- **✓ Succès attendu :** <https://google.fr> → Navigation Internet
- **✗ Échec attendu :** `ping 10.0.40.2` → AD inaccessible
- **✗ Échec attendu :** `ping 10.0.10.1` → VLAN Endpoints inaccessible